

SAST — Semgrep static analysis (server/src)

\$ semgrep scan --config p/security-audit --config p/secrets --config p/nodejsscan server/src 2026-09-03 - Zoom Meeting Intelligence & Relationship Knowledge Base

Scan Status

Scanning 47 files tracked by git with 386 Code rules:

Language	Rules	Files	Origin	Rules
ts	137	47	Community	386
<multilang>	38	47		

6 Code Findings

server/src/index.ts

ajinabraham.njsscan.good.good_helmet_checks.helmet_header_dns_prefetch

((Blocking))

X-DNS-Prefetch-Control header is present and DNS Prefetch Control is enabled. More information: <https://helmetjs.github.io/docs/dns-prefetch-control/>
Details: <https://sg.run/LAX9>

23; app.use(helmet());

ajinabraham.njsscan.good.good_helmet_checks.helmet_header_hsts

((Blocking))

HSTS header is present. More information: <https://helmetjs.github.io/docs/hsts/>
Details: <https://sg.run/6peB>

23; app.use(helmet());

ajinabraham.njsscan.good.good_helmet_checks.helmet_header_ienoopen

((Blocking))

X-Download-Options header is present. More information: <https://helmetjs.github.io/docs/ienoopen/>
Details: <https://sg.run/0W9R>

23; app.use(helmet());

ajinabraham.njsscan.good.good_helmet_checks.helmet_header_nosniff

((Blocking))

Content-Type-Options header is present. More information: <https://helmetjs.github.io/docs/dont-sniff-mimetype/>
Details: <https://sg.run/zXBW>

23; app.use(helmet());

ajinabraham.njsscan.good.good_helmet_checks.helmet_header_x_powered_by

((Blocking))

Default X-Powered-By is removed or modified. More information: <https://helmetjs.github.io/docs/hide-powered-by/>
Details: <https://sg.run/YeP4>

23; app.use(helmet());

ajinabraham.njsscan.good.good_helmet_checks.helmet_header_xss_filter

((Blocking))

X-XSS-Protection header is present. More information: <https://helmetjs.github.io/docs/xss-filter/>
Details: <https://sg.run/23QD>

23; app.use(helmet());

Scan Summary

Scan completed successfully.

Findings: 6 (6 blocking)

Rules run: 175

Targets scanned: 47

Parsed lines: ~100.0%

Scan was limited to files tracked by git

For a detailed list of skipped files and lines, run semgrep with the --verbose flag

Ran 175 rules on 47 files: 6 findings.

npm audit report

esbuild ≤0.24.2

Severity: moderate

esbuild enables any website to send any requests to the development server and read the response - <https://github.com/advisories/GHSA->
fix available via `npm audit fix --force`

Will install vite@8.2.2, which is a breaking change

node_modules/vite/node_modules/esbuild

vite ≤6.4.2

Depends on vulnerable versions of esbuild

node_modules/vite

@vitest/mocker ≤3.0.0-beta.4

Depends on vulnerable versions of vite

node_modules/@vitest/mocker

vitest ≤3.2.5

Depends on vulnerable versions of @vitest/mocker

Depends on vulnerable versions of vite

Depends on vulnerable versions of vite-node

node_modules/vitest

vite-node ≤2.2.0-beta.2

Depends on vulnerable versions of vite

node_modules/vite-node

react-router 6.0.0 - 7.17.0

Severity: moderate

React Router: Open redirect via backslash in <Link> and useNavigate (CVE-2025-68470 bypass) - <https://github.com/advisories/GHSA-wrjc->

React Router: Arbitrary Constructor Injection via deserializeErrors() in React Router SSR Hydration - <https://github.com/advisories/GHSA->

fix available via `npm audit fix --force`

Will install react-router-dom@7.18.3, which is a breaking change

node_modules/react-router

react-router-dom 6.0.0-alpha.0 - 7.17.0

Depends on vulnerable versions of react-router

node_modules/react-router-dom

7 vulnerabilities (5 moderate, 1 high, 1 critical)

To address all issues (including breaking changes), run:

npm audit fix --force

```
DAST — OWASP ZAP baseline scan (live production API)
$ zap-baseline.py -t https://backend-for-zoom.onrender.com/health 2026-09-03 - Zoom Meeting Intelligence & Relationship Knowledge Base

Using the Automation Framework
Total of 5 URLs
PASS: Vulnerable JS Library (Powered by Retire.js) [10003]
PASS: In Page Banner Information Leak [10009]
PASS: Cookie No HttpOnly Flag [10010]
PASS: Cookie Without Secure Flag [10011]
PASS: Cross-Domain JavaScript Source File Inclusion [10017]
PASS: Content-Type Header Missing [10019]
PASS: Anti-clickjacking Header [10020]
PASS: X-Content-Type-Options Header Missing [10021]
PASS: Information Disclosure - Debug Error Messages [10023]
PASS: Information Disclosure - Sensitive Information in URL [10024]
PASS: Information Disclosure - Sensitive Information in HTTP Referrer Header [10025]
PASS: HTTP Parameter Override [10026]
PASS: Information Disclosure - Suspicious Comments [10027]
PASS: Off-site Redirect [10028]
PASS: Cookie Poisoning [10029]
PASS: User Controllable Charset [10030]
PASS: User Controllable HTML Element Attribute (Potential XSS) [10031]
PASS: Viewstate [10032]
PASS: Directory Browsing [10033]
PASS: Heartbleed OpenSSL Vulnerability (Indicative) [10034]
PASS: Strict-Transport-Security Header [10035]
PASS: HTTP Server Response Header [10036]
PASS: Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) [10037]
PASS: Content Security Policy (CSP) Header Not Set [10038]
PASS: X-Backend-Server Header Information Leak [10039]
PASS: Secure Pages Include Mixed Content [10040]
PASS: HTTP to HTTPS Insecure Transition in Form Post [10041]
PASS: HTTPS to HTTP Insecure Transition in Form Post [10042]
PASS: User Controllable JavaScript Event (XSS) [10043]
PASS: Big Redirect Detected (Potential Sensitive Information Leak) [10044]
PASS: Retrieved from Cache [10050]
PASS: X-ChromeLogger-Data (XCOLD) Header Information Leak [10052]
PASS: Cookie without SameSite Attribute [10054]
PASS: X-Debug-Token Information Leak [10056]
PASS: Username Hash Found [10057]
PASS: X-AspNet-Version Response Header [10061]
PASS: PII Disclosure [10062]
PASS: Permissions Policy Header Not Set [10063]
PASS: Timestamp Disclosure [10096]
PASS: Hash Disclosure [10097]
PASS: Cross-Domain Misconfiguration [10098]
PASS: Source Code Disclosure [10099]
PASS: Weak Authentication Method [10105]
PASS: Reverse Tabnabbing [10108]
PASS: Modern Web Application [10109]
PASS: Dangerous JS Functions [10110]
PASS: Authentication Request Identified [10111]
PASS: Session Management Response Identified [10112]
PASS: Verification Request Identified [10113]
PASS: Script Served From Malicious Domain (polyfill) [10115]
PASS: ZAP is Out of Date [10116]
PASS: Absence of Anti-CSRF Tokens [10202]
PASS: Private IP Disclosure [2]
PASS: Session ID in URL Rewrite [3]
PASS: Script Passive Scan Rules [50001]
PASS: Stats Passive Scan Rule [50003]
PASS: Insecure JSF ViewState [90001]
PASS: Java Serialization Object [90002]
PASS: Sub Resource Integrity Attribute Missing [90003]
PASS: Insufficient Site Isolation Against Spectre Vulnerability [90004]
PASS: Charset Mismatch [90011]
PASS: Application Error Disclosure [90022]
PASS: WSDL File Detection [90030]
PASS: Loosely Scoped Cookie [90033]
WARN-NEW: Re-examine Cache-control Directives [10015] x 1
  https://backend-for-zoom.onrender.com/health (200 OK)
WARN-NEW: Storable and Cacheable Content [10049] x 4
  https://backend-for-zoom.onrender.com/ (404 Not Found)
  https://backend-for-zoom.onrender.com/health (200 OK)
  https://backend-for-zoom.onrender.com/robots.txt (404 Not Found)
  https://backend-for-zoom.onrender.com/sitemap.xml (404 Not Found)
WARN-NEW: CSP: Failure to Define Directive with No Fallback [10055] x 3
  https://backend-for-zoom.onrender.com/ (404 Not Found)
  https://backend-for-zoom.onrender.com/robots.txt (404 Not Found)
  https://backend-for-zoom.onrender.com/sitemap.xml (404 Not Found)
FAIL-NEW: 0 FAIL-INPROG: 0 WARN-NEW: 3 WARN-INPROG: 0 INFO: 0 IGNORE: 0 PASS: 64
Automation plan warnings:
  Job spider error accessing URL https://backend-for-zoom.onrender.com/ status code returned : 404 expected 200
```